

Security incident report

Section 1: Identify the network protocol involved in the incident

The tcpdump is structured as follows. First, it is formed by a DNS request and response for the address "yummyrecipesforme.com" (can be noted by the DNS server address: dns.google.domain and the flag A? and A). The foregoing is done at the transport layer of the OSI model using the UDP protocol at port 53.

After the first 4 lines, the next 9 lines reflect logs for the three handshake steps for a TCP connection, can be noted by considering the target address "yummyrecipesforme.com.http", the port http and the flags used the first log uses the flag S (SYN), the next S. (SYN/ACK) and finally . (ACK). All of this is done at the transport layer (OSI) using TCP at port 80.

The next 6 lines refer to a http get connection, associated with the download of the malware file, also using http (using TCP at port 80). All of this is done at the transport layer (OSI) using TCP at port 80.

The following lines repeat the same process described before but with another domain (malicious domain "greatrecipesforme.com.http"). First, DNS request and response for the address "greatrecipesforme.com.http" (can be noted by the DNS server address: dns.google.domain and the flag A? and A), then the three handshake steps for a TCP connection, can be noted by considering the target address "greatrecipesforme.com.http", the port http and the flags used the first log uses the flag S (SYN), the next S. (SYN/ACK) and finally . (ACK), and finally a http get connection, associated with the retrieval of website content, also using http (using TCP at port 80). All of this is done at the transport layer (OSI) using TCP at port 80.

Section 2: Document the incident

The incident occurred at the web server responsible for hosting the website of the organization.

The incident was noticed and reported after multiple customers emailed yummyrecipesforme's helpdesk. They complained that the company's website had prompted them to download a file to access free recipes. The customers claimed that, after running the file, the address of the website changed and their personal computers began running more slowly. The website owner tried logging into the web server but noticed they were locked out of their account.

The cybersecurity analyst used a sandbox environment to open the website without impacting the company network. Then, the analyst ran tcpdump to capture the network traffic packets produced by interacting with the website. The analyst was prompted to download a file claiming it would provide access to free recipes, accepted the download and ran it. The browser then redirected the analyst to a fake website (greatrecipesforme.com), all of this between 14:18 and 14:25 pm.

The cybersecurity team is currently investigating and fixing the issue. The origin of the attack is being investigated. Since the website owner stated that they had been locked out of their administrator account, the team believes the attacker used a brute force attack to access the account and change the admin password. Also, a senior analyst noticed that javascript code had been added to prompt website visitors to download an executable file. Analysis of the downloaded file found a script that redirects the visitors' browsers from yummyrecipesforme.com to greatrecipesforme.com, impacting the performance of end users.

Section 3: Recommend one remediation for brute force attacks

I suggest three key measures to prevent future brute force attacks.

First, considering the administrative account has a default password, it is necessary to change to a stronger password, ideally based on a password policy provided. The organization could follow a password policy from frameworks like NIST SP800-63.

Second, it's highly recommended to use MFA, as a defense in depth security strategy, to reduce the likelihood of compromising user credentials. Even if a threat actor manages to obtain the password, shouldn't be able to access the system thanks to MFA.

Third, limiting the number of login attempts for users is highly recommended,

even if a threat actor manages to bypass the past two measures, the limit in number of attempts could stop him and prevent negative effects in the organization.